

PromptShield

지역 중소기업의 안전한 생성형 AI 활용을 위한
민감정보 유출 차단 게이트웨이

팀원 박주영 · 김주빈 · 이서연 · 지영빈 · 홍재창

제출 2026년 9월 4일

구현 동작하는 시제품 공개 · github.com/FutureAria/PromptShield

01

문제 배경과 대상 사용자

무엇이 문제인가

직원이 생성형 AI에 업무 내용을 붙여넣는 순간, 그 내용은 외부 사업자의 서버로 넘어간다. 견적서를 요약해 달라고 하면 거래처 명과 단가가, 안내문을 써 달라고 하면 고객의 이름과 연락처가 함께 나간다. 문제는 **직원이 그것을 유출이라고 인식하지 못한다**는 점이다. 업무를 빨리 끝내려는 정상적인 행동이 그대로 유출 경로가 된다.

규정으로도 계약으로도 막기 어렵다. 회사가 기업용 계약을 맺어 학습 · 보관 조건을 통제해도, 직원이 자기 개인 계정 창에 붙여넣는 것까지는 통제하지 못한다. “생성형 AI 사용 금지” 공지 역시 직원이 몰래 쓰거나 생산성을 포기하거나 둘 중 하나로 끝난다. **통제해야 하는 대상은 계정이 아니라 회사 밖으로 나가는 경로다.**

대상 사용자 — 왜 지역 중소기업인가

대기업은 이미 답을 갖고 있다. 사내 전용 AI 환경, 정보유출방지(DLP) 솔루션, 사용 지침을 관리하는 법무·보안 인력. 이 셋 다 **비용과 전담 인력**을 전제한다.

지역 중소기업에는 그 전제가 없다. 정보보안 전담자가 없고, 연 단위 라이선스 비용을 감당하기 어렵고, 도입하더라도 운영할 사람이 없다. 대한상공회의소 경제연구원이 2026년 6월 임금근로자 3,000명을 조사한 결과 **중소기업 근로자의 52.7%가 생성형 AI를 업무에 쓰고 있지만 사내 가이드라인을 받은 비율은 24.3%**에 그쳤다. 절반 이상이 지침 없이 이미 쓰고 있다는 뜻이다. **위험은 대기업과 같은데 대응 수단만 없는 상태**가 지금의 지역 중소기업이다.

PromptShield는 “AI를 쓰지 말라”가 아니라 **“위험한 부분만 걸러내고 나머지는 그대로 쓰게 하자”**는 접근이다. 직원의 업무 흐름을 끊지 않으면서, 나가면 안 되는 것만 나가지 않게 한다.

지켜야 할 법적 의무

개인정보를 처리하는 사업자는 규모와 무관하게 다음 의무를 진다. 전담 인력이 없다는 사실이 이 의무를 면제해 주지 않는다.

조항	의무
개인정보 보호법 제17조 · 제26조	제3자 제공 동의 또는 처리위탁 고지 — 외부 AI 서비스 전송이 여기 해당할 수 있다
제23조 · 제24조	민감정보 · 고유식별정보(주민등록번호 등) 처리 제한
안전성 확보조치 기준 제8조①	접속기록 1년 이상 보관(고유식별정보 처리 시 2년)

PromptShield는 이 의무를 **자동으로 이행되는 기본 동작**으로 바꾸는 것을 목표로 한다. 이 기획서가 설명하는 화면과 등급 분기, 승인 흐름은 **이미 동작하는 시제품으로 구현해 공개했다.**

02

해결 방법과 시스템 처리 흐름

직원과 AI 사이에 게이트웨이를 하나 놓는다. 모든 입력은 외부로 나가기 전에 이 게이트웨이를 지난다. 게이트웨이는 입력에서 민감정보를 찾아내고, 위험도에 따라 **네 갈래 중 하나로 보낸다.**

보안 4등급과 처리 방식

등급	무엇이 걸리나	처리	직원 화면에서 일어나는 일
일반	민감정보 없음	외부 또는 내부 LLM 사용	경고 없이 그대로 전송된다
주의	이름, 전화번호, 이메일, 계좌번호	민감정보 마스킹 후 전달	민감 구간을 번호 토큰으로 가린 전송본을 보낸다
기밀	거래처명, 제품코드, 단가, 소스코드	Ollama 내부 LLM 처리	외부로 나가지 않고 사내에서 처리된다
위험	주민등록번호, API 키, 판독 불가 첨부	전송 차단 또는 관리자 승인	전송 버튼이 잠기고 승인 요청 경로만 열린다

등급 결정 원칙은 “가장 높은 등급이 이긴다”이다. 한 문장에 이메일(주의)과 주민등록번호(위험)가 섞여 있으면 위험으로 판정한다. 낮은 등급이 높은 등급을 덮어쓰지 못하게 하는 것이 이 시스템의 안전 설계 핵심이다.

실제로 무슨 일이 일어나는가

주의 등급 요청 하나를 예로 들면 이렇다.

직원 입력	홍길동 010-0000-0000 hong@example.com으로 안내문 보내줘
판정	주의 마스킹 후 전달 · 탐지 3건(이름 · 전화번호 · 이메일)
전송본	[이름1] [전화1] [이메일1]으로 안내문 보내줘
외부 LLM은 전송본만 받는다. 직원은 안내문 초안을 그대로 받아 쓰고, 이름 · 연락처의 실제 값은 회사 밖으로 나가지 않는다. 직원이 따로 지우거나 판단할 일이 없다는 점이 중요하다.	

같은 원칙에서 내용을 읽지 못한 첨부는 ‘일반’이 아니라 ‘위험’이다. PDF나 이미지처럼 검사기가 내용을 확인할 수 없는 파일은 “안전함이 확인되지 않았다”는 뜻이므로 차단한다. 판정 불가가 통과되는 경로를 구조적으로 없앴다.

시스템 처리 흐름

01	직원이 질문 또는 문서 입력
02	Nginx를 거쳐 FastAPI 게이트웨이 수신 — 외부에 열리는 단일 진입점
03	민감정보 탐지
04	보안정책으로 등급 결정 — 가장 높은 등급이 이김
05	등급별 분기 처리
	일반 외부 또는 내부 LLM 주의 마스킹 후 전달 기밀 Ollama 내부 LLM 위험 차단 또는 관리자 승인
06	답변 재검사 — 본선 구현
07	감사 로그 기록 — 원문 미저장
08	사용자에게 결과 표시

승인 예외 처리

위험 등급이라도 업무상 꼭 보내야 할 때가 있다. 직원은 관리자 승인을 요청할 수 있고, 관리자는 셋 중 하나로 답한다. 승인은 원문 그대로, 조건부 승인은 마스킹본으로만 전송을 허용하며, 반려는 사유를 적어 거부한다. 승인은 1회용이라 한 번 전송에 쓴 승인으로 같은 요청을 다시 보낼 수 없다. 승인 하나로 반복 전송하는 우회를 막기 위해서다.

기술 구성

화면 React	게이트웨이 Nginx	백엔드 Python · FastAPI	데이터베이스 PostgreSQL
내부 LLM Ollama 로컬 모델	실행 환경 Docker Compose		

민감정보 탐지 김주빈

탐지 대상은 세 범주다. **개인정보**(주민등록번호·전화번호·이메일·계좌번호·이름), **기업기밀**(거래처명·제품코드·단가 표현), **소스코드와 자격증명**(코드 조각·API 키)이다.

정규식만으로는 부족하고 AI 모델만으로는 무겁다. 네 가지 수단을 겹쳐 쓴다.

1. **정규식** — 형식이 정해진 것. 주민등록번호, 전화번호, 이메일, 계좌번호, API 키
2. **기업 사전** — 회사마다 다른 것. 거래처명, 제품코드, 단가 표현을 관리자가 직접 등록한다
3. **한국어 개체명 인식(NER)** — 규칙으로 잡지 못하는 인명·주소·기관명
4. **문맥 분류** — 같은 값이라도 쓰임에 따라 민감도가 달라지는 경우

소스코드는 기밀, 자격증명(API 키)은 위험으로 나눈다. 코드 조각은 사내에서 처리하면 업무가 이어지지만, 키가 새어 나가면 되돌릴 수 없기 때문이다.

내부 LLM (Ollama) 이서연

기밀 등급을 “차단”이 아니라 “사내 처리”로 흘려보내려면 외부에 나가지 않는 모델이 필요하다. Ollama는 사내 서버에서 오픈 소스 모델을 구동하므로 **입력이 회사 밖으로 나가지 않는다**. 보안 도구를 쓰기 위해 데이터를 외부에 맡기는 모순을 없앴다.

모델 후보는 한국어 처리 품질, 중소기업 하드웨어에서 돌아가는 크기, 상업적 이용이 가능한 라이선스 세 기준으로 고른다. 내부·외부 LLM은 **응답 품질·처리 시간·데이터 이동 범위**로 비교해 등급별 분기 기준을 정한다.

보안정책과 데이터베이스 홍재창

정책은 허용·마스킹·내부처리·차단 네 갈래이며, 2쪽의 4등급과 일대일로 대응한다. 권한은 **직원·승인자·감사자** 세 역할로 나눈다. 감사자에게 조회 권한은 주되 승인 권한은 주지 않아 직무를 분리한다.

PostgreSQL에는 계정과 권한, 검사 결과, 승인 이력, 감사 로그, 기업 사전, 역할 변경 기록을 저장한다. **감사 로그에는 원문도 탐지된 값도 넣지 않고 등급·처리 경로·유형별 건수만 남기며**, 접속기록은 법정 보존 기간에 맞춰 보관한다. 개인정보 최소 수집 원칙과 같은 방향이다.

화면 구성 · 역할 분담 · 일정

화면 구성과 검증 지영빈

직원 화면과 관리자 화면을 합쳐 일곱 개다. 직원은 검사·전송 화면만 쓰고, 관리 화면은 역할에 따라 열린다.

화면	쓰는 사람	하는 일
직원 화면	전체	내용을 검사하고 등급별 경로로 전송한다
승인 대기	승인자	위험 요청을 승인·조건부 승인·반려한다
감사 로그	승인자·감사자	등급·경로·탐지 건수를 조회한다
관리 현황	승인자·감사자	등급 분포와 차단 추이를 본다
기업 사전	승인자	거래처·제품코드를 등록하고 오탐을 미리 확인한다
사용자·권한	승인자	역할을 배정한다
로그인	전체	계정과 역할을 확인한다

검증은 등급별 시나리오로 한다. 민감정보가 없는 요청, 이름·연락처가 섞인 요청, 거래처·단가가 든 요청, 주민등록번호가 든 요청을 각각 넣어 **의도한 경로로 갈라지는지** 확인하고, 승인 왕복과 기업 사전 반영, 역할별 접근 거부를 더해 시연 순서를 구성했

다.

역할 분담

각 팀원은 담당 분야를 조사해 규칙과 구조를 설계했고, 그 설계를 시제품으로 구현해 동작을 확인했다. **같은 분담을 본선까지 이어 각자 담당 모듈을 구현한다.**

팀원	담당	수행 역할
박주영	팀장 · 기획서 통합	문제 정의와 전체 처리 흐름 설계, 4등급 적합성 검토, 게이트웨이 백엔드와 등급 분기 구현, 저장소 구성과 원고 통합
김주빈	민감정보 탐지	탐지 대상 정의, 정규식 · 사전 · NER · 문맥 분류 비교, 시제품에 반영된 탐지 규칙과 판정 기준 설계, F1-score 평가 계획 / 본선: 한국어 NER 탐지기
이서연	Ollama · 내부 LLM	기밀 등급을 사내에서 처리하기 위한 로컬 LLM 채택 근거, 오픈소스 모델 후보 비교와 분기 기준 수립 / 본선: Ollama 모델 선정과 사내 구동
지영빈	화면 · QA · 시연	직원 · 관리자 화면 7종 설계와 프론트엔드 구현, 역할별 접근 통제와 승인 왕복 구현, 등급별 검증 시나리오, Docker Compose 실행 환경 구성
홍재창	데이터보안 · DB	4등급 처리 정책과 직원 · 승인자 · 감사자 권한 분리 설계, 원문을 남기지 않는 감사 로그 구조와 PostgreSQL 데이터 구조 설계 / 본선: 감사 로그 · 권한 스키마 구현

예선까지의 진행과 본선 일정

일자	내용
08-24 — 09-01	분야별 조사 · 담당 문단 작성 · 5쪽 통합
09-02 — 09-03	시제품 구현 — 화면 7종 · 4등급 분기 · 승인 왕복 · 감사 로그
09-04 15:00	예선 기획서 제출
09월 — 10월 초	한국어 NER · 문맥 분류 적용, 답변 재검사 구현
10월	Ollama 실모델 연동, 평가 항목 측정과 임계값 조정
10월 말 — 11월	지역 기업 문서로 오탐률 확인, 본선 시연 리허설 · 발표

기대효과와 향후 계획

기존 방식과 무엇이 다른가

민감정보 탐지 도구와 LLM 게이트웨이를 붙이면 마스킹과 차단까지는 설정만으로 된다. PromptShield가 다른 지점은 그다음이다.

1. **차단 대신 사내 모델로 우회한다.** 기존 게이트웨이의 선택지는 통과 · 마스킹 · 차단 셋뿐이고, 나가면 안 되는 내용은 결국 업무가 멈춘다. PromptShield는 네 번째 갈래를 둔다. 거래처 · 단가 · 소스코드가 든 요청은 차단하지 않고 사내 Ollama로 보내 답을 받는다. 직원은 일을 계속하고 내용은 회사 밖으로 나가지 않는다. 이 경로가 있어야 ‘금지’가 아닌 ‘통제’가 된다.
2. **회사마다 다른 ‘민감함’을 관리자가 직접 정의한다.** 범용 도구는 주민등록번호는 알아도 특정 거래처명이 왜 민감한지는 모른다. 기업 사전을 관리 화면에 두고, **저장하기 전에 정상 업무 문장에 잘못 걸리는지 미리 보여 준다.** 사전을 넓히다가 업무가 막히는 일을 방지한다.
3. **관리 화면이 새 유출 경로가 되지 않게 설계했다.** 민감정보 도구가 관리자 화면에 원문을 모아 보여 주면 유출 지점이 여러 곳에서 한 곳으로 옮겨갔을 뿐이다. 감사 로그에는 유형과 건수만, 승인 화면에는 마스킹본만 넘기고, 감사자와 승인자의 직무를 분리했다.
4. **전담 인력이 없는 조직을 전제로 만들었다.** 사내 서버 한 대에 설치해 쓰는 형태이므로 검사 대상 데이터가 회사 밖으로 나가지 않는다. 보안 도구를 쓰기 위해 데이터를 외부에 맡기는 모순이 없고, 구독 비용도 들지 않는다.

기대효과

관점	효과
직원	AI 사용을 포기하지 않으면서 유출 걱정을 덜 수 있다. 무엇이 왜 걸렸는지 화면에서 바로 확인한다
관리자	누가 어떤 등급의 요청을 얼마나 보냈는지 집계로 파악한다. 원문을 보지 않고도 관리한다
회사	접속기록 보관과 최소 수집 원칙을 자동으로 이행한다. 사고 발생 시 대응 근거가 남는다
지역 산업	전담 인력이 없는 중소기업도 대기업 수준의 통제를 갖출 수 있다

평가 항목

실제 결과값이 아니라 개발 단계에서 측정할 항목이다. 실제 업무 문장으로 만든 시험 세트로 재고, 오탐률이 높게 나오면 기업 사전과 판정 임계값을 조정한다.

01	개인정보 탐지 정밀도 · 재현율 · F1-score
02	정상 정보 오탐률과 민감정보 미탐률
03	마스킹 후 민감정보 잔존 여부
04	보안등급별 라우팅 정확성
05	프롬프트 검사 처리시간
06	주요 시나리오 통과율

향후 계획

- 1. **답변 재검사 구현** — 외부 LLM 응답에 민감정보가 되돌아오는 경우 차단
- 2. **한국어 NER과 문맥 분류 적용** — 규칙으로 잡지 못하는 인명 · 주소 · 기관명 탐지
- 3. **탐지 성능 측정** — 위 평가 항목을 실제 업무 문장으로 측정하고 임계값 조정
- 4. **Ollama 실효모델 시연** — 기밀 등급 요청이 사내 모델에서 답변되는 과정 시연
- 5. **지역 기업 검증** — 실제 업무 문서로 오탐률 확인

공개 저장소

github.com/FutureAria/PromptShield

1쪽에 적은 저장소가 이 시제품이다. `docker compose up` 한 줄로 기동하며, 화면 7종 · 역할별 접근 통제 · 4등급 분기 · 승인 왕복 · 기업 사전 즉시 반영 · 원문을 남기지 않는 감사 로그를 확인할 수 있다. 탐지 규칙과 API 흐름에는 자동 테스트 42개가 붙어 있다. 답변 재검사와 한국어 NER은 본선 개발 대상이다.